

Findings

What the scan found in the tenant.

Needs: ✓ scan complete · ✓ baseline loaded

Based on the scan from this minute · Aug 28, 2026, 6:12 PM. · Baseline: synthetic baseline ⓘ

1 goal in this baseline, 16 apply to this tenant. The rest are under Details with the reason each one does not apply.

Summary

IAMAI compared Contoso Pty Ltd's 1 enabled Conditional Access policy with synthetic baseline (1 policy), matching each policy on what it does. 2 of 16 security goals are in place; 1 partly (a policy covers some of the people, or a weaker control than the goal needs), 13 missing.

5 users in the directory, 4 active in the last 90 days. 1 of 5 enabled users (20%) proved MFA in the last 30 days. 1 user has no MFA method and 3 users are registered but unproven: 4 users to set up before enforcement.

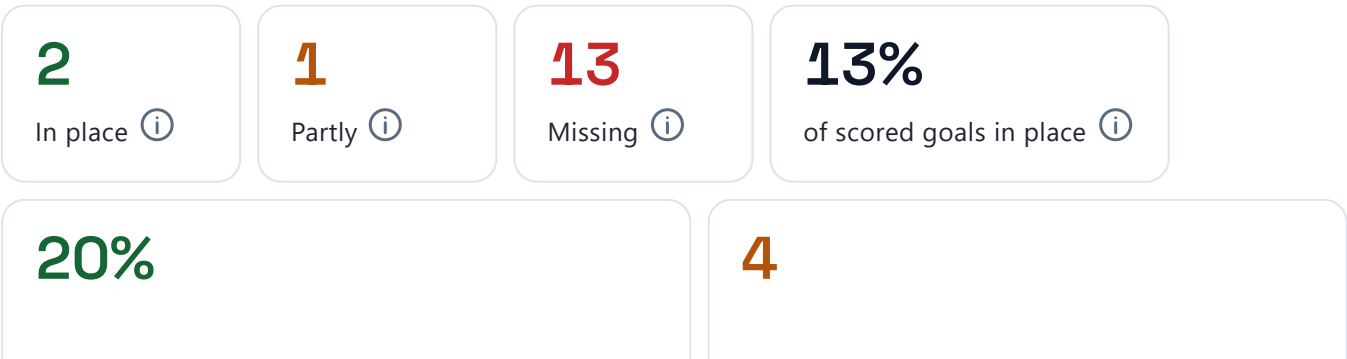
Already in place: every user satisfies MFA on every app, guests satisfy MFA.

Fix first: security-info registration requires a trusted context; device-code flow blocked; authentication transfer blocked. The Roadmap dates each one, names who it touches, and gives the exact change.

5 goals need a licence tier this tenant does not have; they are listed on the Licensing guide and left out of the score.

Since the last checkpoint (Aug 28, 2026): nothing has changed.

ⓘ IAMAI inferred no exclusion groups and 1 likely break-glass account from how the policies use them. Confirm them in [Setup](#) to remove the hedging.



of enabled users proved MFA in the last 30 days ⓘ

enabled users to set up before enforcement ⓘ

Here's what's working

Identity

- ▶ **In place** **Every user satisfies MFA on every app.** Delivered by CA001 - *Require MFA for all users*, with 1 break-glass account excluded. Value 5 Effort 1 Disruption 1 ⓘ

Guests

- ▶ **In place** **Guests satisfy MFA.** Delivered by CA001 - *Require MFA for all users.* Value 5 Effort 1 Disruption 1 ⓘ

Here's what needs attention

Identity

- ▶ **Missing** **Security-info registration requires a trusted context.** No policy does this yet. Proposed: *Security-info registration requires a trusted context.* Value 3 Effort 4 Disruption 2 ⓘ

- ▶ **Partly in place** **Legacy protocols blocked** is in report-only via CA002 - *Block legacy authentication* (30 days, 3 would-be failures). Value 5 Effort 1 Disruption 4 ⓘ

- ▶ **Missing** **Device-code flow blocked.** No policy does this yet. Proposed: *Device-code flow blocked.* Value 3 Effort 1 Disruption 4 ⓘ

- ▶ **Missing** **Authentication transfer blocked.** No policy does this yet. Proposed: *Authentication transfer blocked.* Value 3 Effort 1 Disruption 4 ⓘ

Admins

- ▶ **Missing Admins use phishing-resistant auth.** No policy does this yet. Proposed: *Admins use phishing-resistant auth.* Value 5 Effort 3 Disruption 1 ⓘ

- ▶ **Missing Admin portals need strong auth or are blocked for non-admins.** No policy does this yet. Proposed: *Admin portals need strong auth or are blocked for non-admins.* Value 4 Effort 3 Disruption 3 ⓘ

Devices

- ▶ **Missing Registering or joining a device requires MFA.** No policy does this yet. Proposed: *Registering or joining a device requires MFA.* Value 3 Effort 2 Disruption 3 ⓘ

- ▶ **Missing Unknown platforms blocked.** No policy does this yet. Proposed: *Unknown platforms blocked.* Value 2 Effort 3 Disruption 3 ⓘ

Sessions

- ▶ **Missing Admin sessions expire quickly and never persist.** No policy does this yet. Proposed: *Admin sessions expire quickly and never persist.* Value 4 Effort 2 Disruption 1 ⓘ

- ▶ **Missing Unmanaged-device browser sessions are limited.** No policy does this yet. Proposed: *Unmanaged-device browser sessions are limited.* Value 3 Effort 3 Disruption 2 ⓘ

- ▶ **Missing Windows desktop sessions require token protection.** No policy does this yet. Proposed: *Windows desktop sessions require token protection.* Value 3 Effort 3 Disruption 2 ⓘ

- ▶ **Missing Unmanaged devices cannot download.** No policy does this yet. Proposed: *Unmanaged devices cannot download.* Value 3 Effort 4 Disruption 2 ⓘ

- ▶ Missing **Browser sessions never persist for anyone.** No policy does this yet. Proposed: *Browser sessions never persist for anyone.* Value 2 Effort 2 Disruption 2 ⓘ

Locations

- ▶ Missing **Sign-ins outside allowed countries blocked.** No policy does this yet. Proposed: *Sign-ins outside allowed countries blocked.* Value 3 Effort 3 Disruption 4 ⓘ

Details

- ▶ Does not apply **Office apps require a compliant or joined device:** does not apply (no Intune licence). ⓘ

- ▶ Does not apply **Mobile access requires approved or protected apps:** does not apply (no Intune licence). ⓘ

- ▶ Needs a licence **Risky sign-ins get MFA or are blocked:** needs a licence tier this tenant does not have (p2). Listed on the Licensing guide, not scored. ⓘ

- ▶ Needs a licence **High-risk users must change password:** needs a licence tier this tenant does not have (p2). Listed on the Licensing guide, not scored. ⓘ

- ▶ Does not apply **Azure management requires strong auth:** does not apply (no sign-in activity for Azure management). ⓘ

- ▶ Does not apply **Service principals restricted:** does not apply (no Workload Identities Premium licence). ⓘ

- ▶ Needs a licence **Activating a privileged role asks for MFA every time:** needs a licence tier this tenant does not have (p2). Listed on the Licensing guide, not scored. ⓘ

► Does not apply **Enrolling a device in Intune asks for MFA every time:** does not apply (no Intune licence). ⓘ

► Needs a licence **Medium-risk sign-ins require MFA:** needs a licence tier this tenant does not have (p2). Listed on the Licensing guide, not scored. ⓘ

► Needs a licence **Medium-risk users must change their password:** needs a licence tier this tenant does not have (p2). Listed on the Licensing guide, not scored. ⓘ

Policies not in the baseline

Every policy maps to a goal.

Housekeeping

- Naming: no dominant naming convention yet: the plan uses the baseline's